

State estimation is a critical aspect of the system. Once we've obtained an estimate of the state, we know more or less the current state of the system, and based on that we can take decisions. All the algorithms in the Layer 3 in SCADA takes $\hat{x}$ as values. If we inject false values to the Bad Data Detector, this will lead to having a wrong state estimation, and the controllers will output wrong commands.

In normal operativity, the real state x is close to the cyber state $\hat{x}$. When we have an attack, the state estimation is corrupted, and thus the state estimation is very different from the real state.

Whenever an attacker wants to corrupt the cyber state, he will have to do it in a consistent way. Whenever we falsify measurements, it should be consistent with the physical equations describing the system.

What are the most important algorithms in smart grids?

- Bad data detection: useful to filter measurements.
- State estimation
- Frequency control
- Voltage regulation: keeping the value at a constant value.
- Network stability.
- Fault Isolation and Service Restoration (FISR).

Risk Management

Provides a framework for the activities we're going to do.

Risk Management is a set coordinated activities to direct and control an organisation with regard to risk.

It helps us to deal with risks in a clever and structured way.

What is a risk? It's the effect of uncertainty on objectives. What is an effect? A deviation from an expected situation, which can be positive or negative. Typically, we focus on negative effects. Objectives are regarded to keeping the system up and working.

An event, like an attack, will come from a source. It has an impact on some assets/objectives, and we'll have to quantify this impact, and it has a probability

of occurring. An adverse event starts from a threat that exploits vulnerabilities of an asset.

How do we perform risk management in practice? This is standardised, and called as Risk Management Process, which is the systematic application of management policies, procedures and practice for the activities of communicating, consulting, establishing the context, identifying, analyzing, evaluating, treating.

Whenever we have an incident, most likely something here was not done properly. Some of them are quantitative: from identifying to treating.

Information security and risk management should contribute to the following:

- risks being identified
- risks assessment:
- communication: people involved in a process should be informed about risks.
- prioritization
- stakeholder involvement
- risk treatment
- monitoring of risk management analysis and repetition of the process.

Let's take a look at things again:

- Context establishment: define rules on what we have to do in the process.
- Risk assessment: Composed of:
 - Risk identification: understanding the relevant risks of the organisation.
 - Risk analysis: to study in detail every identified risk.
 - Risk evaluation: what to do with the risks.
- Risk treatment: what to do with the risks practically.
- Risk acceptance: determining the level of the work we've done to address the risks.

In parallel, we have:

- Risk communication and consultation: every stakeholder will have to be informed about these activities.
- Monitoring and review: it's a meta process, we should regularly do an exercise to check whether rules are still OK.

This process is an iterative process, and needs to be repeated periodically, specifically when something in the system is modified.

The first step is context establishment: Sets criteria (methodology) for the risk management, the boundaries and purposes. We also have to define an acceptance threshold, to determine whether to accept a risk or not.

Risk assessment is defined as the process of identification, analysis and evaluation. A risk is a potential that a given threat will exploit vulnerabilities of an asset or group of assets, therefore causing an harm to the organisation. To measure the level of risks, we measure the significance of a risk, which is expressed in terms of the combination of consequences and their likelihood.

So, there are several actors involved: threats, vulnerabilities, assets and damage.

Risk identification is used to determine the important risks in an organization. It's also about determining adverse events that could happen and cause damage.

One methodology is to determine first hand the important assets, which could potentially be targets. Assets could be something physical, workers, customers, data, reputation of the company, etc.

Then, we list potential threats, coming outside the assets, with the potential of causing damages. Threats could have natural or human origin, they could be accidental or deliberate. To have damage, is not sufficient to have a threat. In fact, it should exploit a weakness in an asset, the vulnerability. Vulnerabilities could have several origins, like physical ones, hardware, software.

Then, we need to identify control, which is a measure that maintains and modifies risks.

The presence of a vulnerability itself is not sufficient to cause harm, there has to be a threat as well.

When we want to identify threats and vulnerabilities, we work with already existing lists enumerating possible threats. As we've seen, we can have threats causing physical damages, like fire, water damage.

We also have lists of vulnerabilities.

So, in risks identification, by using lists, we see what are threats and vulnerabilities, matching these and come up with scenarios that we need to study in detail.

Typically, risks are described in a form of incidents scenarios.

Risk analysis is the process used to understand the level of risks. It provides the basis for the following steps. Remember that the level of risk is a combination of the impact (amount of damage on the system), likelihood (probability of a risk scenario happening). There are qualitative and quantitative approaches.

First thing first, we'll have to perform an assessment of consequences, determining the impact, through mathematical analysis and simulations. Then, we analyse the likelihood, but instead of seeing how probable is an attack, we'll see how difficult is to be executed. For the risk level, we combine together the two things.

When we study attacks, in the end we're analysing possible incident scenarios. We'll study this quantitatively.

Then, the next step is risk evaluation. In this, we compare the results of the analysis with the criteria established in the first phase, to determine if the risk level is acceptable or not. We check if it's above or below our acceptance threshold.

Then, we have risk treatment. Here we do something about risks if necessary. It's a process used to modify risks. It can involve:

1. Avoiding the risk by deciding not to start or continue with the activity that gives rise to the risk;
2. Removing risk source
3. Change the likelihood
4. etc.

This was the standard definition.

So, how do we modify the risk? We decide actions (controls to select).

There are four possibilities of risk treatment:

- Risk modification
- Risk retention: if there is a risk level below the risk acceptance threshold, we do nothing.
- Risk avoidance: we avoid that risk at the root.
- Risk sharing: for example, with insurance companies.

After we've treated risks, we have residual risk levels. This is the risk remaining after treatment. We then decide whether this residual value is acceptable or not with risk acceptance.

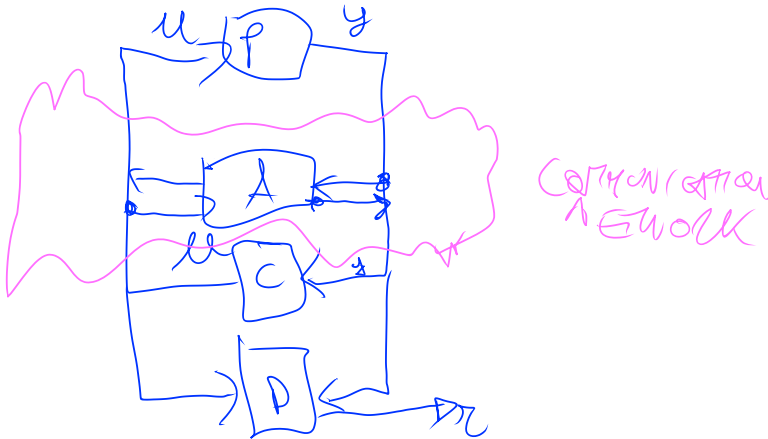
As we've said, we also have parallel processes:

- risk communication and consultation with stakeholders.
- risk monitoring and review: the iterative process is repeated every time it's necessary.

- risk management monitoring, review and improvement: we should check up the process of risk management, to see if we can improve it.

Modelling a CPS

Specifically, we'll deal in the modelling of a networked CPS.



The goal will be to model mathematically this scheme.

Today, let's focus on model of the process. There are two main approaches:

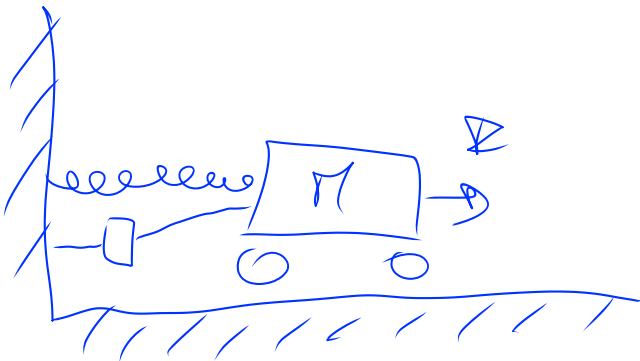
- State space model;
- Transfer function model.

We'll mainly focus on the first, while the second is used for covert attacks design.

So, today we take a look at the state space model of the process. The state space model can be used both for the physical system, but also for algorithms.

Example

We want to model a mass-spring dumper system.



We have a mass, that is free to move horizontally. We apply an external force to

the mass. The mass is also attached to the wall with a spring, but also with a damper ("smorzatore"). This could be a simplified model of a suspension in a car.

How to model?

Steps to derive the state-space model:

1. Identify the control variables (u) (the quantities we can control to modify the system), the output variables (y), and the state variables (x). In general, there are several of these variables. (if applicable, we also identify noise variables, disturbance, and so on)

Now, what is our control goal? Let's say we want to control horizontal position of the mass M (s) by applying a force. So, we have only one input variable, the force. So, $u \equiv F$. While the output $y \equiv s$. As for the state variables? We'll see later.

2. Write all the relevant equations describing how the system works. Typically, they come from physical law that govern the system.
 - Mass. $M \cdot a = \sum \text{external forces applied}$ (Newton Equation). Remember that $a = \dot{v}$, with $v = \dot{s}$.
 - Spring. $F^{\text{spring}} = -k \cdot s$. It's proportional to the force that opposes movement, so we use $(-)$ sign. k is a constant of proportionality, specific for every spring.
 - Damper: $F^{\text{damp}} = -D \cdot v$, with D being a coefficient and $v = \dot{s}$.

The equation describing the coupling of the mass, spring and damper is the newton equation. Thus:

$$M \cdot a = \sum_{\text{sum of external forces}} F^e = F - k \cdot s - D \cdot v$$

It's a differential equation, as we can write:

$$M \cdot \ddot{s} = F - k \cdot s - D \cdot \dot{s} \quad \text{second-order ordinary diff. equation}$$

We want now to derive an abstract model written in terms of control (u), output (y) and state variables (x).

The model has this form:

$$\begin{cases} \dot{x} = A \cdot x + B \cdot u & \text{state equations, tells us how state changes } *_1 \\ y = C \cdot x + D \cdot u & \text{output equations, give output as function } *_2 \end{cases}$$

$*_1$ depending on the state.

$*_2$ of current state and current control.

Remember that x, u, y are vectors in general, thus A, B, C and D are matrices.

Now, our goal is to turn the $M \cdot a$ equation we've seen before, in the one seen in the $\begin{Bmatrix} \cdot \\ \cdot \end{Bmatrix}$.

3. Identify state variables. Rules: Every variable that is derived is a state variable.

In this example we are computing $v = \dot{s}$, thus s is one state variables. But we are also computing $a = \dot{v}$, so v is the second state variable. So, we have two state variables.

$$x = \begin{pmatrix} x_1 \\ x_2 \end{pmatrix} = \begin{pmatrix} s \\ v \end{pmatrix} \quad \text{state is the set of all variables we need to compute } *_1$$

*₁ future evolution of the system, depending on the applied input.

4. Rewrite physical equations by replacing u, y, x and with only first order derivatives

We start from $M \cdot \ddot{s} = F - k \cdot s - D \cdot \dot{s}$. Thus $M \cdot \ddot{s} = u - k \cdot x_1 - D \cdot x_2$. We also have $\ddot{s} = \dot{v} = \dot{x}_2$.

$$\begin{cases} M \cdot \dot{x}_2 = -k \cdot x_1 - D \cdot x_2 + u \\ \dot{x}_1 = x_2 \end{cases}$$

Another way to procede:

We now know that $x = \begin{pmatrix} x_1 \\ x_2 \end{pmatrix}$, we know we must arrive at $\dot{x} = A \cdot x + B \cdot u$. So we start by computing $\dot{x}_1 = v = x_2$. To find $\dot{x}_2 = \dot{v} = \ddot{s}$ which we can find from Newton equation.

$\dot{x}_1$ is actually obvious, while the second one comes from Newton.

Thus, finally we have as state equation:

$$\begin{cases} \dot{x}_1 = 0x_1 + 1x_2 + 0u \\ \dot{x}_2 = -\frac{k}{M}x_1 - \frac{D}{M}x_2 + \frac{1}{M}u \end{cases}$$

What is the output equation? Remember that we want to control the movement s , so $y = 1x_1 + 0x_2 + 0u$.

So these two equations are the state space model of process in scalar form.

We can also write this in matrix form. We form matrices looking at coefficients.

$$\begin{cases} \dot{x} = \begin{pmatrix} \dot{x}_1 \\ \dot{x}_2 \end{pmatrix} = \underbrace{\begin{pmatrix} 0 & 1 \\ -\frac{k}{M} & -\frac{D}{M} \end{pmatrix}}_A \begin{pmatrix} x_1 \\ x_2 \end{pmatrix} + \underbrace{\begin{pmatrix} 0 \\ \frac{1}{M} \end{pmatrix}}_B u \\ y = \underbrace{\begin{pmatrix} 1 & 0 \end{pmatrix}}_C \cdot \begin{pmatrix} x_1 \\ x_2 \end{pmatrix} + \underbrace{0}_D u \end{cases}$$

Why do we use state space? Mainly for analysis purpose.

Imagine we have P_1, P_2, P_3 (physical systems). For P_1 we might have Newton law as physical equations, for P_2 we use the kirchoff equation, for P_3 we use the chemical equation.

But then, by analyzing the state space we see they have the same state space model, thus having the same properties. We'll study these properties, which depend on A, B, C, D matrices.

Examples of analysis is given by:

- solution of the model. This state space model is known as implicit model (having $\dot{x}$ and not x), and we want to get to an explicit model. This step is called solution.
- other properties: stability, controllability, observability, which are also linked to the possibility of undetectable attacks.

The state space is an abstraction step. From the state space, we know how to analyse properly things of the system.